

Unit – 1 Introduction of Information Security and Cryptography

1. Introduction to Information Security

Information Security is the **practice of protecting information** from **unauthorized access, misuse, modification, or destruction** from **unauthorized access, disclosure alteration, destruction** or any form of cyber threat.

In simple words:

👉 *Keeping information safe from people who should not see, change, or destroy it.*

Why Information Security is Needed

1. Protect Confidential Information

Prevents unauthorized access to sensitive data such as passwords, personal and financial information.

2. Ensure Data Integrity

Ensures that information is not altered or modified without permission.

3. Maintain Availability of Information

Ensures that systems and data are accessible to authorized users whenever required.

4. Prevent Cyber Attacks

Protects systems from attacks such as hacking, malware, and data theft.

5. Protect User Privacy

Safeguards personal and private information of users.

6. Ensure Business Continuity

Prevents data loss and system failure, ensuring smooth operation of organizations.

1.2 CIA Triad

The **CIA Triad** is the **foundation of Information Security**.

It stands for:

1. **C – Confidentiality**
2. **I – Integrity**
3. **A – Availability**

1. Confidentiality

Confidentiality means **information is accessible only to authorized persons.**

Unauthorized users shouldn't be able to access your personal information.

👉 No one else should see the data.

How Confidentiality is Achieved

- Passwords
 - Encryption
 - Authentication
 - Access control
-

Example: Exam paper kept locked before exam

If Confidentiality Fails

- Data leakage, Privacy loss, Identity theft
-

2. Integrity

Integrity means **data should not be altered or modified without authorization.**

👉 Data must remain **correct and trustworthy.**

How Integrity is Maintained

- Hash functions
 - Digital signatures
 - Access control
-

Simple Example

- Marks entered in system should not be changed by students
 - Bank balance should not be modified illegally
-

If Integrity Fails

- Wrong information
- Financial loss
- Loss of trust

3. Availability

Availability means **information and systems should be accessible when needed.**

👉 Authorized users must get data **on time.**

How Availability is Ensured

- Backup systems
- Redundant servers

Simple Example

- Bank website should work during business hours
 - Email should be accessible anytime
-

If Availability Fails

- System downtime
 - Service interruption
 - Business loss
-

CIA Triad – One Line Memory Trick (Exam Friendly)

- **Confidentiality** → *Who can see the data*
 - **Integrity** → *Data should not change*
 - **Availability** → *Data should be available when needed*
-

OSI Security Architecture

Simple Meaning

The **OSI Security Architecture** is a **framework defined by ISO** that explains:

- **What security services are needed**
- **How security is provided**
- **What types of attacks exist**

It helps us **understand and design security** in computer networks.

👉 It does **NOT** depend on any specific OSI layer, but applies to **all layers.**

Why OSI Security Architecture is Needed

Because in networks:

- Data travels over insecure channels
- Many users share the same network
- Attacks can happen at any point

So OSI defined a **standard security model** to:

- Identify threats
 - Provide protection methods
 - Standardize security concepts
-

OSI Security Architecture has 3 Parts

1. **Security Services**
 2. **Security Mechanisms**
 3. **Security Attacks**
-

1. Security Services

Types of Security Services

1. Authentication

Authentication ensures that the sender or user is genuine.

👉 Verifies *identity*.

Example

- Login using username & password
 - OTP verification
-

2. Access Control

Access control ensures only authorized users can access resources.

Example

- Students can view marks but cannot edit them
 - Admin has full access
-

3. Data Confidentiality

Ensures data is not disclosed to unauthorized users.

Example

- Encrypted emails
 - HTTPS websites
-

4. Data Integrity

Ensures data is not altered during transmission or storage.

Example

- Digital signatures
 - Hash values
-

5. Non-Repudiation

Ensures sender cannot deny sending the message.

Example

- Online payment receipt
 - Digital signature in email
-

6. Availability

Ensures systems and data are available when required.

Example

- Backup servers
- Protection from DoS attacks

2. Security Mechanisms

Types of Security Mechanisms

A. Specific Security Mechanisms

1. Encryption

- Converts plain text into cipher text
- Provides confidentiality

Example: AES, RSA

2. Digital Signature

- Ensures integrity + non-repudiation
- Uses private & public keys

3. Access Control Mechanism

- Restricts access based on permissions

4. Authentication Exchange

- Passwords, OTP, certificates

5. Traffic Padding

- Adds dummy data to hide traffic pattern

6. Data Integrity Mechanism

- Hash functions, MAC

7. Routing Control

- Chooses secure routes for data

8. Notarization

- Trusted third party confirms transactions
-

B. Pervasive Security Mechanisms

These support the entire system.

1. **Trusted Functionality**
 2. **Security Labels**
 3. **Event Detection**
 4. **Security Audit Trail**
 5. **Security Recovery**
-

Simple Example

- **Encryption** → Confidentiality
 - **Hashing** → Integrity
 - **Firewall** → Access control
 - **Backup** → Availability
-

3. Security Attacks

Definition

An **attack** is a **deliberate attempt to exploit a vulnerability** in order to **violate security policies** such as confidentiality, integrity, or availability.

Types of Security Attacks

1. Passive Attacks

Attacker only listens, does not alter data.

Types

1. **Eavesdropping**
2. **Traffic Analysis**

Example

- Listening to network communication
- Reading data without changing it

👉 Hard to detect

2. Active Attacks

Attacker modifies, deletes, or disrupts data.

Types

1. **Masquerade** – pretending to be someone else
2. **Replay** – reusing captured data
3. **Modification of Message**
4. **Denial of Service (DoS)**

Example

- Website shutdown
- Altering bank transaction

👉 Easier to detect but harmful

➤ Threat

A **threat** is a **potential cause of an unwanted incident** that may result in **damage to a system, network, or information** by exploiting a vulnerability.

THREAT	ATTACK
Threat can be intentional or unintentional	Attack is intentional
May or may not be malicious	Attack is malicious
Circumstance that has the ability to cause damage	Objective is to cause damage
Information may or may not be altered or damaged	Chance for information alteration and damage is very high
Comparatively hard to detect	Comparatively easy to detect
Can be blocked by control of vulnerabilities	Cannot be blocked by just controlling the vulnerabilities
Can be classified into Physical threat, internal threat, external threat, human threat, and non-physical threat.	Can be classified into Virus, Spyware, Phishing, Worms, Spam, Botnets, DoS attacks, Ransomware, Breaches.

Cryptography

Cryptography is the technique of **protecting information by converting it into an unreadable form** so that only authorized users can understand it.

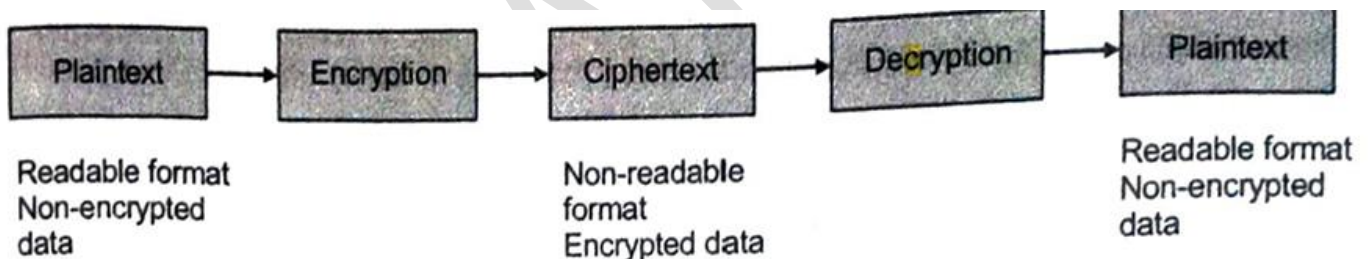
Cryptanalysis

Cryptanalysis "Cryptanalysis is the **technique of decoding messages from a non-readable format back to a readable format** without knowing how they were initially converted from readable format to nonreadable format.

Cryptology- "Cryptology is a combination of cryptography and cryptanalysis "

Cryptography + Cryptanalysis = Cryptology

- Original message → **Plaintext**
- Encrypted message → **Ciphertext**
- Process of encoding plaintext to ciphertext → **Encryption**
- Reverse process ciphertext to plaintext → **Decryption**



Types of Cryptography

There are **two main types**:

1. **Private Key Cryptography** (Symmetric Key)
2. **Public Key Cryptography** (Asymmetric Key)

1. Private Key Cryptography (Symmetric Key Cryptography)

In **Private Key Cryptography**, the **same secret key** is used for:

- Encryption
- Decryption

👉 Sender and receiver **share one common key**.

👉 Private key cryptography mainly provides: **Confidentiality**

Working (Step-by-Step)

1. Sender encrypts data using **secret key**
2. Encrypted data is sent
3. Receiver decrypts data using **same secret key**

Simple Example

Think of a **locked box**:

- One key opens and locks it
- Both sender and receiver have the **same key**

Common Algorithms

- AES (Advanced Encryption Standard)
- DES (Data encryption standard)
- 3DES
- Blowfish

Advantages

- Fast processing
- Suitable for large data
- Simple implementation

Disadvantages

- Key sharing problem
 - Less secure for large networks
 - If key is stolen → security fails
-

2. Public Key Cryptography (Asymmetric Key Cryptography)

In **Public Key Cryptography**, two different keys are used:

- **Public Key** – shared with everyone by receiver
- **Private Key** – kept secret with receiver only

👉 What one key encrypts, **only the other can decrypt**.

Working (Step-by-Step)

1. Sender encrypts message using **receiver's public key**
 2. Encrypted message is sent
 3. Receiver decrypts message using its own **private key**
-

Simple Example

Think of a **post box**:

- Anyone can drop letters (public key)
 - Only owner can open it (private key)
-

Common Algorithms

- RSA (Rivest Shamir Adleman)
 - ECC (Elliptic Curve Cryptography)
-

Advantages

- No key sharing problem
 - Better security
 - Supports digital signatures
-

Disadvantages

- Slower than private key
 - Not suitable for large data
-

👉 **Public key cryptography provides:**

- Confidentiality
- Authentication
- Non-repudiation

Symmetric Key Encryption (Private Key Cryptography)	Asymmetric Key Encryption (Public Key Cryptography)
Single key for both Encryption and Decryption.	A public key is used for Encryption and a private key used for Decryption.
The size of cipher text is the same or smaller than the original plain text.	The size of cipher text is the same or larger than the original plain text.
The encryption process is very fast.	The encryption process is slow.
Used to transfer large amount of data.	Used to transfer small amounts of data.
Only provides confidentiality.	Provides confidentiality, authenticity, and non-repudiation.
The length of key used is 128 or 256 bits	The length of key used is 2048 or higher
Resource utilization is low as compared to asymmetric key encryption.	Resource utilization is high.
More efficient	Less efficient.
Less secure because uses same key.	More secure as two keys are used here- one for encryption and the other for decryption.
Examples : 3DES, AES, DES and RC4	Examples : Diffie-Hellman, ECC, El Gamal, DSA and RSA

1.5 Message Digest (MD5) Hashing & SHA

Hashing is the process of generating a fixed-size output value from variable length block of data as an input.

Hash Function

A hash function converts input data of any size into a fixed-length output, called a message digest.

The main objective of the hash function is to achieve data integrity.

👉 It is a one-way function:

- Can hash data
- Cannot reverse hash back to original data

Why Hashing is Used

- To ensure **data integrity**
- To store **passwords securely**
- To detect **data modification**
- Used in **digital signatures**

Simple Example

- Input: HELLO
- Hash output: 8b1a9953c4611296a827abf8c47804d7

Even a **small change** in input gives a **completely different hash**.

Cryptographic Hashing Algorithms

MD5 (Message Digest Algorithm 5)

MD5 is a widely known cryptographic **hash function** that produces a 128-bit (16-byte) hash value.

Key Characteristics of MD5

- Fixed output size: 128 bits
- One-way function (cannot get original message back)
- Fast computation
- Designed by Ron Rivest
- Used for data integrity

Working of MD5 (High-Level Steps)

1. Input message is padded (appending bits to the original message)
 2. Message is divided into blocks
 3. Each block is processed through rounds (mathematical equation)
 4. Final 128-bit hash is generated
-

Example

- Input: password
 - MD5 Hash: 5f4dcc3b5aa765d61d8327deb882cf99
-

Uses of MD5

- File integrity checking
 - Checksums (detect errors)
 - Password hashing (earlier systems)
-

Limitations of MD5

- Not secure today
 - Vulnerable to collision attacks
 - Two different inputs can generate same hash
-

SHA (Secure Hash Algorithm)

SHA is a family of secure cryptographic hash functions developed by NIST.

More secure than MD5

Types of SHA

- SHA-1 → 160 bits
- SHA-256 → 256 bits
- SHA-512 → 512 bits

Working of SHA (General Idea)

1. Message padding
 2. Message divided into blocks
 3. Multiple rounds of processing
 4. Final fixed-length hash output
-

Example (SHA-256)

- Input: HELLO
 - Output: 3733cd977ff8eb18b987357e22ced99f46097f31ecb239e878ae63760e83e4d5
-

Uses of SHA

- Digital signatures
- SSL / TLS
- Blockchain
- Password storage
- File integrity verification

Feature	MD5	SHA
Output size	128 bits	160–512 bits
Security	Weak	Strong
Collision resistance	Poor	High
Current use	Not recommended	Widely used
Designed by	Ron Rivest	NIST

Hashing	Encryption
One-way	Two-way
No key used	Key used
Used for integrity	Used for confidentiality
Cannot retrieve data	Can decrypt data

Working of SHA (Very Simple Explanation)

Think of SHA as a machine that creates a digital fingerprint of data.

Step-by-Step Working of SHA

Step 1: Input Message

You give any data to SHA:

- Text
- File
- Password

Example:

HELLO

Step 2: Padding (Making Message Proper Length)

SHA first **adds extra bits** to the message so that its length becomes suitable for processing.

👉 This is only for internal calculation.

Step 3: Breaking into Blocks

The padded message is **divided into fixed-size blocks**.

Each block is processed **one by one**.

Step 4: Processing (Mixing the Data)

Each block goes through **multiple rounds of mathematical operations**:

- Shifting
- Mixing
- Combining bits

👉 This makes the data **highly scrambled**.

Step 5: Generate Hash (Message Digest)

After all blocks are processed, SHA produces a **fixed-length output**.

Example (SHA-256):

- Input: HELLO
- Output: 3733cd97...

Unit – 2 Network and System security

2.1 Types of Attacks

An attack is an attempt to violate security policies and compromise confidentiality, integrity, or availability of a system or network.

A. General Point of View

1. Criminal Attacks

- Performed for financial gain
- Includes fraud, data theft, ransomware

Example: Stealing bank details, online scams

2. Publicity Attacks

- Performed to gain fame or attention
- Often done by hackers or hacktivists

Example: Website defacement with hacker name

3. Legal Attacks

- Performed by authorized agencies
- Used for investigation or surveillance

Example: Lawful interception by government agencies

B. Technical Point of View

1. Passive Attacks

Attacker monitors or listens to communication without modifying data.

Types

a) Release of Message Contents

- Unauthorized reading of data
- Violates confidentiality

Example: Reading emails, passwords

b) Traffic Analysis

- Observing communication patterns
- Used even if data is encrypted

Example: Identifying frequently contacted servers

2. Active Attacks

Definition:

Attacker modifies, deletes, or disrupts data or services.

Types

a) Masquerade

- Attacker pretends to be an authorized user

Example: Login using stolen credentials

b) Modification

- Unauthorized alteration of data

Example: Changing transaction details

c) Denial of Service (DoS)

- Makes system or network unavailable

Example: Flooding a server with requests

C. Implementation Point of View

1. Application-Level Attacks

- Target software and applications
- Exploit application vulnerabilities

Example:

SQL injection, malware in applications, change the amount in a transaction.

2. Network Level Attacks

These attacks may slow down, or completely halt the computer system network, Once an attacker get control over network, he may apply application-level attacks also

Example:

DoS, packet sniffing, spoofing

- **General view** → motive of attack
 - **Technical view** → behaviour of attack
 - **Implementation view** → attack location
-

2.2 Digital Signatures

- A digital signature is a **cryptographic technique** that **uses public key cryptography to verify the authenticity, integrity, and non-repudiation** of a digital message or document.
 - Digital signatures can **provide evidence of origin, identity** and status of electronic documents, transactions or digital messages
-

Properties of Digital Signature

1. Authentication

Confirms the identity of the sender.

2. Integrity

Ensures that the message has not been altered during transmission.

3. Non-Repudiation

Sender cannot deny sending the message.

4. Unforgeability

Digital signature cannot be created by unauthorized users.

5. Verifiability

Receiver can verify the signature using the sender's public key.

2.3 PRETTY GOOD PRIVACY (PGP)

- Pretty Good Privacy (PGP) is a cryptographic software program used to provide security for e-mail communication by using encryption, digital signatures, and hashing.
- It uses best cryptographic algorithms such as RSA, Diffie-Hellman key exchange, DSS for the public-key encryption (or) asymmetric encryption.
- **CAST-128 3DES IDEA is used for symmetric encryption and SHA-1 is used for hashing purposes**
- PGP software is an **open-source software and independent of OS** (Operating System)

Key Features of PGP

- Provides **confidentiality**
- Ensures **authentication**
- Maintains message **integrity**
- **Compression**
- Email Compatibility

Applications

- Secure e-mail communication
- File encryption
- Secure data transfer

Email Authentication using PGP

Email authentication using **PGP (Pretty Good Privacy)** is used to **prove that an email is really sent by the claimed sender and has not been changed.**

How PGP Authenticates an Email (Simple Steps)

Step 1: Message Creation

The sender writes an email message.

Step 2: Hashing the Message

- PGP creates a **hash (message digest)** of the email using a hash function (MD5/SHA).
- This hash represents the **fingerprint of the message.**

Step 3: Creating Digital Signature

- The hash is **encrypted using the sender's private key.**
- This encrypted hash becomes the **digital signature.**

Step 4: Sending the Email

The sender sends:

- Original email message
- Digital signature

Step 5: Signature Verification (Receiver Side)

- Receiver decrypts the digital signature using the **sender's public key.**
- Receiver also creates a new hash of the received message.

Step 6: Authentication Result

- If both hashes match:
 - Sender is authenticated
 - Message is not modified
- If not:
 - Email is rejected

What Email Authentication Ensures

- **Authentication** → sender is genuine
- **Integrity** → message not altered

Non-repudiation → sender cannot deny sending

2.4 Secure Socket Layer (SSL)

SSL is a security protocol used to **protect data sent over the internet**.

- It **encrypts** data so others cannot read it
- It **verifies the identity** of the website
- It creates a **secure connection** between browser and server

Example: When you see **https://** and a lock icon in the browser, SSL/TLS is working.

Transport Layer Security (TLS)

TLS is the **newer and more secure version of SSL**.

- It does the **same job as SSL**
- More secure and efficient
- Used everywhere today

👉 In real life, we say “SSL”, but actually **TLS** is used.

How SSL/TLS Works (Simple)

1. You try to open a secure website
2. Website sends its **certificate** (identity proof)
3. Browser checks if the website is genuine
4. A **secret session key** is created
5. Data is encrypted using that key

After this, all communication is **safe and private**.

Why SSL/TLS is Important

- Protects passwords and personal data
- Prevents data stealing
- Ensures safe online payments
- Protects against attackers on the network

2.5 IPsec (Internet Protocol Security)

What is IPsec?

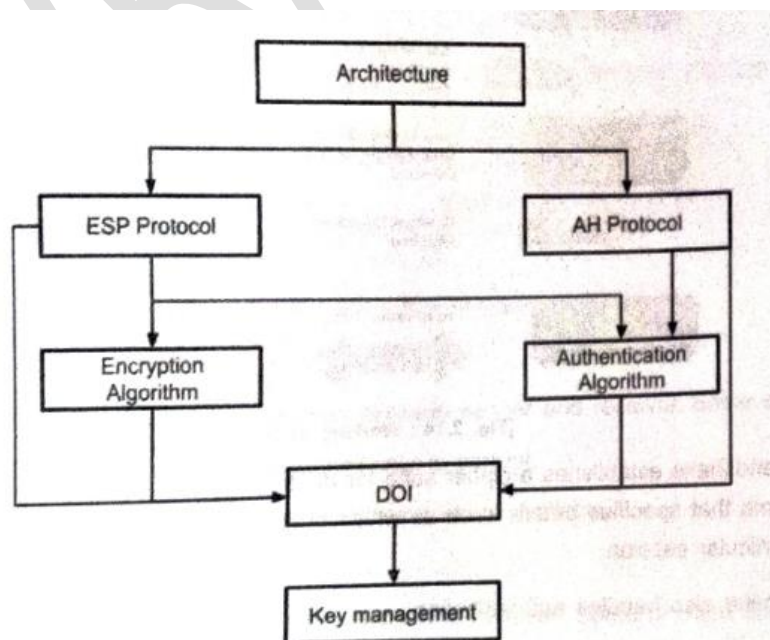
IPsec is a set of rules (protocols) used to **secure data at the IP (network) layer**. It protects data while it is **travelling over a network**.

👉 IPsec works **below applications**, so it secures **all IP traffic automatically**.

What IPsec Provides

- **Confidentiality** → encryption of data
- **Integrity** → data not modified
- **Authentication** → sender is genuine
- **Anti-replay protection** → prevents reuse of packets

IPsec Architecture



[Fig. 2.15 : IP Security Architecture]

IPsec architecture consists of **four main components**:

1. Architecture

This is the top-level framework of IPsec.

It controls and coordinates:

- **AH protocol**
 - **ESP protocol**
 - **Encryption algorithms**
 - **Authentication algorithms**
 - **Key management**
-

2. ESP Protocol (Encapsulating Security Payload)

- ESP is used to provide confidentiality.
 - It uses encryption algorithms to encrypt data.
 - It can also provide authentication and integrity.
-

3. Encryption Algorithm

- Used by ESP
- Encrypts IP data to keep it secret
- Ensures confidentiality

Examples: AES, DES (not required in diagram explanation)

4. AH Protocol (Authentication Header)

- AH is used to provide:
 - Authentication
 - Integrity
 - It does not encrypt data
-

5. Authentication Algorithm

- Used by AH
 - Verifies sender identity
 - Ensures data is not modified
-

6. DOI (Domain of Interpretation)

- Acts as a link between protocols and key management

- Defines:
 - Which algorithms are used
 - How security parameters are interpreted
-

7. Key Management

- Responsible for:
 - Generating keys
 - Exchanging keys
 - Managing keys securely
 - Usually implemented using IKE (Internet Key Exchange)
-

2.6 HTTPS

HTTPS (Hyper Text Transfer Protocol Secure) is a secure version of HTTP that uses SSL/TLS to provide encrypted and authenticated communication between client and server.

Working of HTTPS

HTTPS works by establishing a **secure communication channel** between a client and a server using **SSL/TLS protocol**.

Working of HTTPS

1. Normal HTTP communication is not secure

- In HTTP, data is sent as **plain text**.
- Anyone on the network (like on public Wi-Fi) can **sniff and read** the data.
- Example: username and password can be seen by attackers.

2. HTTPS uses SSL/TLS for security

- HTTPS uses an **encryption protocol** called **TLS**

3. Secure connection establishment

- When a browser connects to a website using HTTPS,
- SSL/TLS creates a **secure encrypted connection** between browser and web server.

4. Data encryption

- Before sending data, HTTPS **encrypts the information**.
- Encrypted data looks like **random, meaningless characters**.

5. Secure data transfer

- Even if encrypted data packets are intercepted or sniffed,
- The attacker **cannot understand or read the data**.

6. Safe communication

- The web server decrypts the data and processes it normally.
- Thus, usernames, passwords, and sensitive data remain **secure**.

Advantages of using HTTPS

- Secure Communication
- Data Integrity
- Privacy and security
- Faster performance

HTTP	HTTPS
The full form of HTTP is Hypertext Transfer Protocol	The full form of HTTPS is Hypertext Transfer Protocol Secure.
It operates on application layer.	It operates at the transport layer.
The data is transferred in plain text form.	The data is transferred in encrypted form, i.e., ciphertext.
By default, this protocol operates on port number 80.	By default, this protocol operates on port number 443.
The URL start with http://	The URL start with https://
This protocol does not need any certificate.	But this protocol requires an SSL (Secure Socket Layer) certificate.
Communication carried out without encryption.	Communication carried out with encryption.
Faster than HTTPS.	Slower than HTTP.
It is un-secure.	It is highly secure.
Examples of HTTP websites are Educational Sites, Internet Forums, etc.	Examples of HTTPS websites are shopping websites, banking websites, etc.

2.7 Malicious Software (Malware)

Malicious software (Malware) is any program intentionally designed to damage, disrupt, steal, or gain unauthorized access to a computer system or network.

1. Virus

A **virus** is a malicious program that **attaches itself to a legitimate file or program** and **replicates when the host program is executed**.

Characteristics

- Requires a host program
- Spreads when infected file runs
- Can corrupt or delete data

Example

Virus attached to an executable file.

2. Trojan Horse

A **Trojan horse** is a malicious program that **appears to be legitimate software** but performs **harmful actions in the background**.

Characteristics

- Does not replicate
- Tricks users into installing it
- Used to steal data or create backdoors

Example

Fake software or cracked applications.

3. Rootkit

A **rootkit** is a malicious tool designed to **gain and hide privileged (root-level) access** to a system.

Characteristics

- Hides malware and attacker activities
- Difficult to detect
- Allows long-term control

Example

Root access hidden from system monitoring tools.

4. Backdoor

A **backdoor** is a **hidden method of bypassing normal authentication** to gain access to a system.

Characteristics

- Can be installed by attackers or developers
- Bypasses security checks
- Used for remote access

Example

Hidden login account in a system.

5. Keylogger

A **keylogger** is a malicious program that **records keystrokes** made by a user.

Characteristics

- Captures passwords and personal data
- Runs silently in background
- Sends data to attacker

Example

Recording ATM PIN or login credentials.

6. Adware

Adware is unwanted software designed to throw advertisements up on your screen most often a web browser

1. **Virus** → spreads using another file
2. **Trojan** → fake but harmful
3. **Rootkit** → hides attacker
4. **Backdoor** → secret entry
5. **Keylogger** → records typing

2.8 Firewall

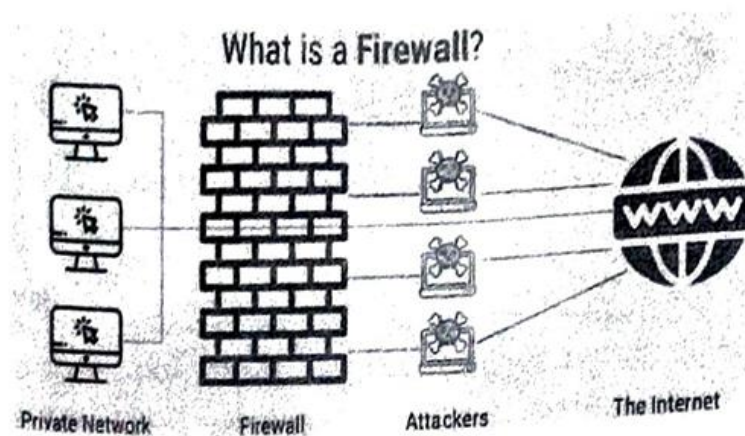
A **firewall** is a **security system** that **monitors and controls incoming and outgoing network traffic** based on predefined security rules.

Need of Firewall

A firewall is needed to:

1. **Prevent unauthorized access** to a system or network
2. **Protect internal network** from external attacks
3. **Block malicious traffic** such as viruses and hackers
4. **Control network traffic** using security rules
5. **Improve overall network security**

Example: A company network uses a firewall to block unknown users from the Internet.



[Fig. 2.20 : Firewall working Architecture]

Types of Firewalls

1. Network-Based Firewall

A **network-based firewall** is installed **between networks** and protects the **entire network**.

- Works at **network level**
- Filters traffic entering or leaving the network
- Usually placed at **network gateway**

Example:

Firewall used in offices, colleges, organizations.

Advantages:

- Protects multiple systems
- Centralized security control

2. Host-Based Firewall

A **host-based firewall** is installed on a **single computer or host**.

- Protects only that system
- Controls incoming and outgoing traffic of the host
- Works at **system level**

Example:

Windows Firewall, Linux firewall.

Advantages:

- Protects individual systems
- Allows user-level control

Network-Based Firewall	Host-Based Firewall
Protects entire network	Protects single system
Installed at gateway	Installed on host
Central control	Local control
Used in organizations	Used on personal systems

Advantages of Firewalls

1. Protects systems from **unauthorized access**
2. Blocks **malicious traffic** from the network
3. Controls **incoming and outgoing network traffic**
4. Helps prevent **hacking and malware attacks**
5. Improves **overall network security**
6. Allows implementation of **security rules and policies**

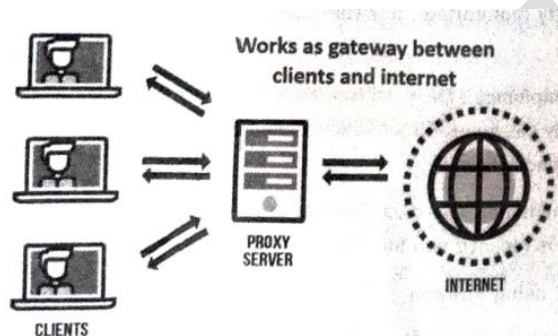
Disadvantages of Firewalls

1. Cannot protect against **internal attacks** completely
2. Cannot stop attacks that **bypass the firewall**
3. May **block legitimate traffic** if misconfigured
4. Cannot detect **all types of malware**
5. Requires **regular maintenance and updates**
6. Can reduce **network performance** slightly

2.9 PROXY SERVER

The proxy server is a computer on the internet that accepts the incoming requests from the client and forwards those requests to the destination server. It works as a gateway between the end-user and the internet. It plays an intermediary role between users and targeted websites or servers.

- A **proxy server** is an **intermediate system** that sits between a **user (client)** and the **internet**.
- Instead of connecting directly to a website, the client sends the request to the proxy, and the proxy forwards it to the internet.



[Fig. 2.22 : Working of proxy server]

2.9.3 Need for using proxy servers

- It reduces the chances of data breaches.
- It adds a subsidiary layer of security between server and outside traffic.
- It also protects from hackers.
- It filters the requests.
- It improves the security and enhances the privacy of the user.
- It hides the identity (IP address) of the user.
- It controls the traffic and prevents crashes.

Types of Proxy Server

1. Open or Forward Proxy

- Used by clients
- Client sends request to proxy
- Proxy accesses internet on behalf of client

Example:

Used in offices and colleges to control user access.

2. Reverse Proxy

- Used by servers
- Sits in front of web servers
- Handles client requests on behalf of servers

Example:

Used for load balancing and security.

3. Transparent Proxy (port 80)

- User is not aware of proxy
 - Automatically intercepts traffic
 - Used for filtering and monitoring
-

4. Anonymous Proxy

- Hides user's IP address
 - Provides privacy and anonymity
-

5. Caching Proxy

- Stores frequently accessed data
- Reduces bandwidth usage
- Improves access speed

Unit – 3 Cyber Crime

3.1 Overview of Cybercrime

Overview

Cybercrime refers to crimes that are **committed using computers, networks, or the internet**. It includes activities like hacking, fraud, identity theft, and data theft. With the growth of technology, cybercrime has increased rapidly and affects individuals, businesses, and governments.

Cybercrime

Cybercrime is any illegal activity where a **computer, network, or digital device is used as a tool or target**.

Cybercriminals

Cybercriminals are individuals or groups who **use computers and technology to perform illegal activities** such as hacking, fraud, or stealing data.

Hacker vs Cybercriminal

Basis	Hacker	Cybercriminal
Meaning	Person who accesses systems and networks	Person who commits crimes using computers
Purpose	Can be legal or ethical (security testing)	Always illegal and harmful
Intent	May improve system security	Intends to steal, damage, or misuse data
Legality	Can be legal (ethical hacker) or illegal	Always illegal activity
Examples	Ethical hacker testing security	Fraudster, identity thief, online scammer

3.2.1 Cyber Crimes Against Organization

a. Email Bombing

Email bombing is an attack where a large number of emails are sent to a target system. This overloads the mail server and may cause it to crash or slow down. It disrupts communication and normal operations of the organization.

b. Salami Attack

In a salami attack, small amounts of data or money are stolen repeatedly. Each transaction is so small that it is not easily noticed. Over time, it results in a large loss for the organization.

c. Logic Bomb

A logic bomb is a malicious program that activates when a specific condition is met. It may delete files or damage systems on a certain date or event. It is often hidden inside legitimate software.

d. Trojan Horse

A Trojan horse is a malicious program that appears as useful software. Once installed, it gives unauthorized access to attackers. It can steal data or damage the system without the user knowing.

e. Web Jacking

Web jacking is the act of taking control of a website without permission. The attacker may change content or redirect users to another site. It can damage the reputation of the organization.

f. Data Diddling

Data diddling involves changing data before or during input into a system. It is often done to manipulate financial or official records. This leads to incorrect information and losses.

g. Denial of Service (DoS / DDoS)

DoS attacks flood a system with excessive requests to make it unavailable.
DDoS uses multiple systems to perform the attack, making it stronger.
It disrupts services and prevents users from accessing the system.

h. Ransomware

Ransomware is malware that locks or encrypts system data.
The attacker demands payment to restore access.
It can cause major financial loss and data unavailability.

3.2.2 Cyber Crimes Against Individual

a. Cyber Bullying

Cyber bullying is the act of **harassing or threatening a person using digital platforms**.
It includes abusive messages, posts, or sharing harmful content.
It can affect the victim mentally and emotionally.

b. Cyber Stalking

Cyber stalking involves **continuously monitoring or following someone online**.
The attacker may send repeated messages or track activities.
It creates fear and invasion of privacy.

c. Cyber Defamation

Cyber defamation is the act of **spreading false or harmful information about a person online**.
It damages the person's reputation and social image.
It is commonly done through social media or websites.

d. Phishing

Phishing is a method where attackers **trick users into giving sensitive information**.
They use fake emails or websites that look real.
Information like passwords or bank details is stolen.

e. Cyber Fraud and Cyber Theft

Cyber fraud involves **cheating people online for financial gain**.
Cyber theft means **stealing data, money, or personal information**.
Both cause financial loss to individuals.

f. Spyware

Spyware is software that **secretly monitors user activities**.
It collects personal data like passwords and browsing habits.
It works without the user’s knowledge.

g. Email Spoofing

Email spoofing is sending emails by **faking the sender’s identity**.
It makes the email look like it comes from a trusted source.
Used to trick users into sharing information.

h. Man-in-the-Middle Attack

In this attack, the attacker **secretly intercepts communication between two users**.
They can read or modify the data being exchanged.
It is commonly used to steal sensitive information.

Spoofing vs Phishing

Basis	Spoofing	Phishing
Meaning	Faking identity (email, IP, website) to appear trusted	Tricking users to share sensitive information
Goal	To disguise as a trusted source	To steal data like passwords, bank details
Method	Uses fake identity or address	Uses fake emails, messages, or websites
User Interaction	May not always require user action	Requires user to click or enter details
Example	Fake email address or IP spoofing	Fake bank login page asking for password

3.2.3 Cyber Crimes Against Society

a. Cyber Pornography

Cyber pornography involves **publishing or distributing obscene or illegal content online**. It includes videos, images, or websites that violate laws or social norms. It can negatively impact individuals and society, especially youth.

b. Cyber Terrorism

Cyber terrorism is the use of **computers and networks to attack government or public systems**. It aims to create fear, damage infrastructure, or disturb national security. Examples include hacking critical systems like power or defense.

c. Cyber Spying

Cyber spying is the act of **secretly collecting confidential or sensitive information** using digital means. It is often done by hackers or organizations for political or economic benefit. It targets governments, companies, or individuals.

d. Social Engineering Attack

Social engineering is a technique of **manipulating people to reveal confidential information**. Attackers use trust, fear, or emotions instead of technical hacking. Common examples include fake calls or emails asking for passwords.

e. Online Gambling

Online gambling involves betting or playing games for money over the internet. It can lead to financial loss and addiction. In many places, it is illegal or regulated.

3.2.4 Cyber Crimes Against Property

a. Credit Card Fraud

Credit card fraud is the **unauthorized use of someone's credit card details** to make transactions. Attackers steal card information through phishing, hacking, or skimming. It leads to financial loss for the card owner.

b. Software Piracy

Software piracy is the **illegal copying, sharing, or use of software without permission**. It violates license agreements and causes loss to software companies. Common examples include cracked or duplicate software.

c. Copyright Infringement

Copyright infringement is the **unauthorized use or copying of someone's original work** like music, movies, or books. It ignores the rights of the creator or owner. It is punishable by law.

d. Trademark Violations

Trademark violation is the **unauthorized use of a company's brand name, logo, or symbol**. It creates confusion among customers and damages brand value. Often seen in fake or duplicate products.

3.3 Challenges & Prevention of Cyber Crime

Challenges of Cyber Crime

1. Anonymity of Attackers

Cybercriminals can hide their identity using fake accounts, VPNs, or dark web. This makes it very difficult to trace the real person behind the crime.

2. Rapid Growth of Technology

Technology is changing very fast, and new tools are developed regularly. Security systems often fail to keep up with new types of cyber attacks.

3. Lack of Awareness

Many users do not have proper knowledge about cyber threats. They easily fall into traps like phishing or fake websites.

4. Jurisdiction Issues

Cybercrimes can be committed from any country. Different laws in different countries make investigation and punishment difficult.

5. Shortage of Skilled Professionals

There is a lack of trained cybersecurity experts. This makes it harder to prevent and investigate cybercrimes effectively.

6. Data Privacy Issues

Large amounts of personal data are stored online. Protecting this data from misuse is a major challenge.

7. Difficulty in Evidence Collection

Digital evidence can be easily deleted or modified. Proper collection and preservation require special tools and skills.

Prevention of Cyber Crime

1. Use Strong Passwords

Create strong and unique passwords using letters, numbers, and symbols.
Avoid using simple or common passwords.

2. Install Antivirus and Firewall

Security software helps detect and prevent malicious activities.
Firewall controls unauthorized access to the system.

3. Regular Software Updates

Keep operating system and applications updated.
Updates fix security vulnerabilities and bugs.

4. Avoid Suspicious Links and Emails

Do not click on unknown links or attachments.
They may contain malware or phishing attacks.

5. Secure Networks

Use secure Wi-Fi networks and avoid public networks for sensitive work.
Enable encryption and strong passwords for Wi-Fi.

6. Data Backup

Regularly backup important data.
It helps recover information in case of ransomware or data loss.

7. User Awareness and Training

Educate users about cyber threats and safe practices.
Awareness is the first step to prevention.

8. Use Multi-Factor Authentication (MFA)

Add an extra layer of security beyond passwords.
It makes unauthorized access more difficult.

3.4 Cyber Law

Cyber Law

Cyber law refers to the **legal rules and regulations related to computers, internet, and digital activities.**

It deals with cybercrimes, electronic records, and online transactions.

Information Technology Act, 2008

The IT Act, 2008 is a law in India that **provides legal recognition to electronic records and controls cybercrimes.**

It defines offences and punishments related to misuse of computers and internet.

Offences under IT Act

Section 65 – Tampering with Computer Source Documents

This section deals with **intentionally hiding, destroying, or altering computer source code.**

It is a punishable offence as it affects system integrity.

Section 66 – Computer Related Offences

This section covers acts like **hacking, data theft, and unauthorized access.**

It applies when someone dishonestly or fraudulently misuses computer systems.

Section 67 – Publishing Obscene Content

This section deals with **publishing or transmitting obscene or illegal content online.**

It includes images, videos, or messages that are offensive or harmful.

Unit – 4 Ethical Hacking

Definition

Hacking is an activity done to gain unauthorized access to a computer system or a computer network either to harm the systems or to steal sensitive information available on the computer.

- Earlier, hackers were skilled programmers solving complex problems.
 - Now, hacking is mostly used for illegal access to systems.
 - It can be harmful (stealing data) or useful (finding system weaknesses).
 - People who perform hacking are called **hackers**.
-

Types of Hacking

- **Password Hacking** – Stealing or cracking passwords
 - **Computer Hacking** – Gaining access to a computer system
 - **Network Hacking** – Controlling or disturbing a network
 - **Website Hacking** – Taking control of a website
 - **Email Hacking** – Accessing someone's email without permission
 - **Ethical Hacking** – Finding and fixing system weaknesses legally
-

Types of Hackers

1. White Hat Hackers

- Ethical hackers
- Work legally to improve security

2. Black Hat Hackers

- Malicious hackers
- Steal data or damage systems

3. Grey Hat Hackers

- Mix of both
- May hack without permission but not always harmful

4. Green Hat Hackers

- Beginners in hacking
- Learning stage

5. Blue Hat Hackers

- Take revenge or test systems
- Not regular professionals

6. Red Hat Hackers

- Act against black hat hackers
- Try to stop cybercriminals

4.2 Basics of Ethical Hacking

4.2.1 What is Ethical Hacking?

Definition

Ethical hacking is the process of **identifying weaknesses in computer systems or networks and fixing them to improve security**, with proper permission.

Rules of Ethical Hacking

- Take **written permission** before testing
 - Maintain **privacy of organization data**
 - Report all **security weaknesses clearly**
 - Inform vendors about **software/hardware issues**
-

4.2.2 Why Ethical Hacking?

- **Protects Information**
Keeps important data safe and maintains company reputation
 - **Prevents Financial Loss**
Avoids loss due to cyberattacks (e.g., banking frauds)
 - **Stay Ahead of Hackers**
Finds weaknesses before cybercriminals exploit them
 - **Improves Security**
Strengthens systems and networks
 - **Legal Activity**
Done with permission, unlike illegal hacking
-

Basic Terms

- **Hacking** – Finding and exploiting system weaknesses
- **Cybercrime** – Crime using computers or internet
- **Ethical Hacking** – Legal hacking to improve security

4.3 Terminology of Hacking

1. Vulnerability

Definition

A vulnerability is a **weakness or flaw in a system, network, or software** that can be exploited by attackers.

- Weakness or flaw in system, network, or software
- Makes system unsafe and open to attacks
- Security gap that attackers can target

Example: Weak password, outdated software

2. Exploit

Definition

An exploit is a **method or tool used to take advantage of a vulnerability** to gain unauthorized access.

- Method or tool used to attack a vulnerability
- Helps attacker gain unauthorized access
- Uses system weakness to break security

Example: Using a bug to hack a system

3. Zero-Day (0-Day)

Definition

A Zero-Day is a **new vulnerability that is unknown to the system owner or developer and has no fix available yet.**

- New and unknown vulnerability
- No fix or patch available yet
- Very dangerous as no protection exists

Example: New virus attack before software update

4.4 Five Steps of Hacking

1. Information Gathering

- Collect details about target system/network
 - Includes IP address, domain, employees, technologies used
 - Done using public sources and basic tools
-

2. Scanning

- Identify open ports, services, and system weaknesses
 - Helps attacker find entry points
 - Uses tools to scan network and systems
-

3. Gaining Access

- Exploit vulnerabilities to enter the system
 - Can involve password cracking, malware, or attacks
 - Attacker gets control of system/data
-

4. Maintaining Access

- Attacker keeps long-term access
 - Installs backdoors or malware
 - Used for continuous monitoring or repeated attacks
-

5. Covering Tracks

- Removes evidence of attack
 - Deletes logs and hides activities
 - Avoids detection by system or authorities
-

4.5 Information Gathering (Reconnaissance)

Information Gathering

Information gathering is the first step of ethical hacking where the attacker collects important details about the target system or network.

The main aim is to understand the system and find possible weak points for attack.

Information Collected

- **Security policies** – Gives idea about how the system is protected and where weaknesses may exist
 - **Network details** – Includes IP address range, network type (LAN/WAN), subnet, etc.
 - **Employee details** – Emails, phone numbers, social media (useful for social engineering attacks)
 - **Host information** – Operating system, version, and system configuration
-

Steps in Information Gathering

- Collect initial/basic information about target
 - Identify network range and structure
 - Find active machines in network
 - Discover open ports and entry points
 - Identify operating system of systems
 - Detect services running on ports
 - Create a map of the network
-

Types of Information Gathering

1. Active Reconnaissance

In this method, the attacker directly interacts with the target system to collect information. It provides accurate and detailed data, but there is a high chance of being detected.

- Direct interaction with target system
 - More accurate and detailed data
 - Higher risk of detection
-

2. Passive Reconnaissance

In this method, the attacker collects information without directly interacting with the target. It uses public sources like websites and social media, so it is safer but gives limited data.

- No direct interaction with target
- Uses public sources (websites, social media)
- Less risk of detection

Basic Commands Kali Linux

Command	Use	Example
ls	List files and directories	ls
cd	Change directory	cd Documents
pwd	Show current directory path	pwd
mkdir	Create new directory	mkdir test
rmdir	Remove empty directory	rmdir test
rm	Delete files	rm file.txt
cp	Copy files/directories	cp file.txt backup/
mv	Move or rename files	mv file.txt new.txt
cat	View file content	cat file.txt
clear	Clear terminal screen	clear
touch	Create empty file	touch file.txt
echo	Display text / write into file	echo Hello
man	Show command manual/help	man ls
whoami	Show current user	whoami
chmod	Change file permissions	chmod 777 file.txt

a. Footprinting

Footprinting is the process of **collecting basic information about a target system or organization** such as IP address, domain details, and employee data before an attack.

b. Scanning

Scanning is used to **identify open ports, services, and vulnerabilities** in a system to find possible entry points for attack.

c. Password Cracking

Password cracking is the process of **breaking or guessing passwords** to gain unauthorized access to a system or account.

d. Brute Force Attacks

Brute force attack is a method where the attacker **tries all possible password combinations** until the correct one is found.

e. Injection Attacks

Injection attacks occur when an attacker **inserts malicious code (like SQL)** into an application to access or manipulate data.

f. Phishing Attacks

Phishing is a technique where attackers **trick users into providing sensitive information** (like passwords or bank details) using fake emails or websites.

g. Blockchain Attacks

Blockchain attacks are attempts to **exploit weaknesses in blockchain networks**, such as double spending or 51% attack, to gain unfair advantage.

BASIC TERMINOLOGIES

1. **Adware** – Software that automatically displays unwanted advertisements on a user's system.
2. **Attack** – An action performed to gain unauthorized access or extract sensitive data from a system.
3. **Backdoor** – A hidden method of bypassing normal authentication to access a system.
4. **Bot** – A program that automates tasks over a network without human intervention.
5. **Botnet** – A network of compromised computers controlled remotely by an attacker.
6. **Brute Force Attack** – A method of gaining access by trying all possible password combinations.
7. **Buffer Overflow** – A condition where excess data overflows into adjacent memory, causing errors or exploitation.

8. **Clone Phishing** – A phishing attack where a legitimate email is copied and modified with malicious links.
9. **Cracker** – A person who breaks into systems or software for illegal purposes.
10. **Denial of Service (DoS)** – An attack that makes a system or service unavailable by overwhelming it.
11. **Distributed DoS (DDoS)** – A DoS attack carried out using multiple systems targeting a single system.
12. **Firewall** – A security system that monitors and controls incoming and outgoing network traffic.
13. **Keystroke Logging** – The process of recording keys pressed on a keyboard to capture sensitive data.
14. **Logic Bomb** – Malicious code that activates when a specific condition is met.
15. **Master Program** – A program used to control multiple infected systems in a botnet.
16. **Phreaker** – A person who illegally manipulates telephone networks.
17. **Rootkit** – Software designed to hide malicious processes and provide unauthorized access.
18. **Shrink Wrap Code Attack** – Exploiting vulnerabilities in unpatched or poorly configured software.
19. **Social Engineering** – The practice of tricking people into revealing confidential information.
20. **Spam** – Unsolicited or unwanted messages sent in bulk, usually via email.
21. **Threat** – A potential danger that can exploit a system's vulnerability.
22. **Spoofing** – A technique where an attacker pretends to be a trusted source to gain access.
23. **Spyware** – Software that secretly collects user information without their consent.
24. **Cross-Site Scripting (XSS)** – An attack where malicious scripts are injected into trusted websites.
25. **Zombie Drone** – A compromised computer controlled remotely to perform malicious activities.

4.7 Port Scanning

Port Scanning

Port scanning is a technique used to **check open ports and services running on a system or network**. It helps attackers or ethical hackers find entry points.

Key Points

- Every system has ports (like doors) for communication
- Open ports indicate running services (HTTP, FTP, etc.)
- Attackers use this to find weak points

Types of Port Scanning

- **TCP Scan** – Checks full connection
- **SYN Scan** – Fast and less detectable
- **UDP Scan** – Checks UDP ports
- **Ping Scan** – Checks if system is active

Uses

- Identify vulnerabilities
 - Network security testing
 - Detect unauthorized services
-

4.8 Remote Administration Tool (RAT)

RAT

RAT is a software that allows a user to **control another computer remotely**.

Key Points

- Can access files, camera, keyboard, etc.
- Used legally by administrators
- Used illegally by hackers to spy

Functions of RAT

- File access and transfer
 - Screen monitoring
 - Keylogging (record typing)
 - Remote command execution
-

4.9 Protection from RAT

How to Protect System

- Install **antivirus and firewall**
 - Avoid downloading unknown files
 - Do not open suspicious emails/links
 - Keep system and software updated
 - Use strong passwords
 - Disable unknown applications
 - Monitor system activity regularly
-

4.10 Sniffing and Session Hijacking

Sniffing

Sniffing

Sniffing is the process of **capturing and analyzing network data packets**.

Key Points

- Used to monitor network traffic
- Can capture passwords and data
- Done using sniffing tools

Types

- **Passive Sniffing** – Just monitoring (no change)
 - **Active Sniffing** – Manipulating traffic
-

Mechanism of Sniffing

- Data travels in packets over network
 - Sniffer tool captures these packets
 - Extracts useful information like login data
-

Session Hijacking

Session Hijacking

It is the process of **taking control of an active user session** to gain unauthorized access.

Key Points

- Attacker steals session ID
- Gains access without login
- Common in web applications

Types

- **Active Hijacking** – Takes over session
- **Passive Hijacking** – Only monitors session

Unit – 5 Digital Forensics

5.1 Introduction to Digital Forensics

Definition

Digital forensics is the process of collecting, analyzing, and preserving digital data from devices like computers and mobiles to use as evidence in investigations.

- It deals with finding and examining digital evidence from electronic devices.
- It is mainly used in cybercrime investigations and legal cases.
- It ensures data is handled safely so it can be used in court.

A cyberattack creates confusion about how it happened, its impact on data, and recovery steps. Digital forensics helps answer these questions, supports investigation, and improves security to prevent future attacks.

Uses of Digital Forensics

- **Intellectual Property Theft** – Finds stolen data like designs, software, ideas
- **Industrial Espionage** – Detects company secrets stolen by competitors
- **Employment Disputes** – Checks employee misuse of systems
- **Fraud Investigations** – Identifies online scams and financial frauds
- **Internet/Email Misuse** – Tracks improper use in workplace
- **Forgeries** – Detects fake digital documents/signatures
- **Bankruptcy Investigations** – Finds hidden assets or financial data

Advantages of Digital Forensics

- Ensures integrity (safety) of computer systems
- Provides valid evidence in court
- Helps companies recover important data
- Tracks cybercriminals globally
- Saves organization time and money

Disadvantages of Digital Forensics

- Very costly to collect and store data
- Requires high technical knowledge
- Needs strong and convincing proof in court
- Wrong tools can reject evidence
- Lack of skills may lead to wrong results

5.2 Locard's Principle of Exchange in Digital Forensics

Locard's Principle states that **whenever two objects or persons come into contact, there is always an exchange of material or information.**

- Every crime leaves some trace behind.
 - Criminals take something from the scene and also leave something.
 - In digital forensics, this exchange happens in the form of **data and digital traces.**
 - Investigators use these traces to find evidence and reconstruct events.
-

Types of Evidence

- **Physical** – clothes, glass, paint
 - **Biological** – DNA, fingerprints
 - **Natural** – soil, pollen
 - **Digital** – files, logs, images, videos
-

Locard's Principle in Digital Forensics

1. Digital Contact

- Interaction between devices/users creates data exchange
- Example: login, file transfer, internet usage

2. Exchange of Digital Evidence

- Data is created, modified, or deleted
- Leaves traces like logs, timestamps, metadata

3. Analysis of Digital Artifacts

- Experts analyze logs, files, network activity
- Helps to understand sequence of events

4. Chain of Custody

- Evidence must be properly handled and recorded
- Ensures it is valid in court

5. Tools and Techniques

- Special tools are used to collect and analyze data
 - Data should not be altered during investigation
-

Limitations of Locard's Principle

- Evidence may be **tampered or destroyed**
- Scene may be changed by people or environment
- Secondary transfer of evidence may confuse results
- Lack of proper handling can reduce accuracy